

Mapeo de objetivos GQM y métricas SSVC a requisitos normativos y marcos de referencia

Esta tabla relaciona cada objetivo y métrica GQM con requisitos normativos (especialmente NIS2) y marcos oficiales (SSVC, KEV, Vulnrichment) relevantes. [web:24][web:19][web:6][web:22][web:25][web:33][web:39]

Objetivo / Métrica	Descripción resumida	Referentes normativos / marcos	Relación principal
G1 / M1.1	% CVE relevantes con SSVC básico	SSVC (CERT/CC, SEI) [web:24][web:19]; CISA Vulnrichment [web:22] [web:28]	NIS2 exige priorizar según riesgo; disponer de datos SSVC es condición necesaria para priorización informada. [web:33] [web:39]
G1 / M1.2	% CVE con SSVC revisado localmente	SSVC como marco adaptable por contexto [web:24][web:19]; rol de CERT nacionales (INCIBE-CERT, CCN-CERT) [web:7] [web:10]	Permite cumplir expectativas de supervisión nacional, añadiendo contexto específico de país/sector al modelo global. [web:33]
G2 / M2.1	% activos críticos con identificadores normalizados	NIS2 – descubrimiento y gestión de activos [web:33][web:39]; NIST CSF ID.AM	Inventario robusto con CPE/SBOM es base para cumplir obligaciones de gestión de vulnerabilidades.
G2 / M2.2	% activos críticos cubiertos por CVE con SSVC	NIS2 – mitigación de riesgos conocidos [web:33][web:39]; KEV/SSVC [web:6] [web:25][web:24]	Conecta inventario con vulnerabilidades priorizables, imprescindible para demostrar diligencia.
G3 / M3.1	Tiempo medio global de enriquecimiento SSVC	CISA Vulnrichment y cronología de enriquecimiento [web:22][web:19]	Ayuda a justificar y gestionar ventanas de riesgo antes de disponer de datos completos.
G3 / M3.2	Tiempo medio de ajuste SSVC local	Rol de los CSIRT nacionales en NIS2 [web:33]; guías CERT/CC sobre adaptación SSVC [web:24][web:19]	Mide la capacidad de los CERT nacionales para contextualizar rápidamente las recomendaciones globales.
G4 / M4.1	Distribución Act/Attend/Track	SSVC – acciones recomendadas [web:24][web:30]; CISA uso de SSVC en KEV [web:6][web:25]	Refleja política nacional de priorización; puede utilizarse como base de obligaciones sectoriales. [web:33]

G4 / M4.2	Distribución por sector	NIS2 – sectores esenciales/importantes [web:33][web:39]	Permite analizar consistencia de la política de priorización entre sectores y ajustar guías sectoriales.
G5 / M5.1	MTTR para Act	NIS2 – tiempos de respuesta razonables [web:33][web:39]; prácticas recomendadas de métricas [web:32] [web:27]	Mide la agilidad de remediación frente a vulnerabilidades prioritarias; apto para supervisión.
G5 / M5.2	% Act en plazo	NIS2 – cumplimiento de medidas de seguridad y mitigación [web:33][web:39]	Puede integrarse en planes de supervisión y eventualmente en regímenes sancionadores.
G6 / M6.1	Tasa de discrepancias nacional vs local	NIS2 – coordinación entre autoridades competentes y operadores [web:33] [web:39]	Detecta desalineación entre política nacional y decisiones de operadores; útil para diálogo regulatorio.
G6 / M6.2	% discrepancias justificadas	NIS2 – accountability y documentación de decisiones de riesgo [web:33]	Asegura que las desviaciones no son arbitrarias, sino basadas en análisis documentado.
G7 / M7.1	% incidentes graves por Track/Attend	Estudios empíricos CVSS/EPSS/SSVC [web:16][web:20]; NIS2 – impacto de incidentes [web:33][web:39]	Mide la eficacia real del modelo de priorización; indicador clave para revisión de políticas.
G7 / M7.2	Tendencia de M7.1	NIS2 – mejora continua [web:33]	Permite demostrar (o refutar) que la evolución del modelo SSVC reduce errores de priorización.
G8 / M8.1	Exposición acumulada a KEV-Act	CISA KEV [web:6] [web:25]; BOD 22-01 sobre remediación de vulnerabilidades explotadas [web:30]	Conecta obligaciones de remediación rápida con la realidad de exposición de activos críticos.
G8 / M8.2	Exposición media por sector	NIS2 – evaluación sectorial de riesgos [web:33][web:39]	Permite comparar sectores y enfocar esfuerzos de supervisión donde la exposición es mayor.

G9 / M9.1	Reducción interanual de backlog crítico	Informes sobre estado de la gestión de vulnerabilidades [web:27][web:38] [web:32][web:35]	Mide la capacidad del sistema para no acumular deuda técnica crítica.
G9 / M9.2	Reducción de MTTR tras SSVC	Documentos de adopción SSVC [web:19][web:24]; informes industriales [web:27][web:32]	Aporta evidencia de que SSVC y datos enriquecidos tienen impacto tangible en tiempos de respuesta.

Este mapeo puede complementarse con referencias jurídicas nacionales específicas en función de la transposición de NIS2 y otras normativas sectoriales (financiero, energía, salud, etc.).